

Understanding Multi-factor Authentication

Estimated time needed: 10 minutes

Introduction

Multi-factor authentication (MFA) is a security mechanism that requires users to provide two or more verification factors to access a resource such as a system, network, or application. This process enhances the security of the protected resource by creating multiple layers of defense against unauthorized access.

Three factors of multi-factor authentication

MFA is based on the premise that an unauthorized user is unlikely to be able to provide all the required verification factors. These factors are divided into three categories:

1. **Something you know** - This is information known only to the user, such as a password, a PIN, or the answer to a secret question.
2. **Something you have** - This factor involves a physical device in the user's possession. It could be a security token, a bank card, a smartphone, or a hardware dongle.
3. **Something you are** - The most personal factor includes biometric data like fingerprints, retinal patterns, voice recognition, or the user's behavior patterns.

Single-Factor Authentication (SFA) is a security process where users provide only one authentication factor to verify their identity, typically a password. If the password is compromised, there's no additional layer of security to prevent unauthorized access. This is the most basic form of authentication, commonly used in personal email or social media accounts.

Two-Factor Authentication (2FA) involves two different types of authentication factors. This could be a combination of something the user knows (like a password or PIN), something the user has (like a smart card or mobile device), or something the user is (such as a fingerprint or retinal scan). This method is more secure than SFA as it adds an extra layer of security. Online banking often uses 2FA, requiring a password and a one-time code sent to the user's mobile device.

Multi-Factor Authentication (MFA) involves two or more independent categories of credentials to verify the user's identity for a login or other transaction. MFA can include two-factor authentication but also can consist of more. The aim is to create a layered defense and make it more difficult for an unauthorized person to access a target such as a physical location, computing device, network, or database. If one factor is compromised or broken, the attacker still has at least one more barrier to breach before successfully breaking into the target.

Determining the appropriate multi-factor authentication method

Choosing the proper MFA method depends on various factors, including the sensitivity of the data, the location of access, the user's device's convenience, and the user's capability.

For example, for online banking, a combination of something the user knows (like a password) and something the user has (such as a mobile phone to receive a one-time password) would suffice. However, involving all three factors to maximize security is crucial in high-security settings like labs.

When allowing remote access to company resources, the emphasis should be on maintaining a balance between security and user convenience. A combination involving a password (something the user knows) and a one-time password generated on a smartphone app (something the user has) is generally considered effective and user-friendly.

Remember, MFA aims to enhance security without overly complicating the user experience.

Author

Dee Dee Collette



Skills Network